

Statement of Work

AI-Powered Vehicle Damage Assessment — Insurance Claims Intake

Client	Insurance Company (Prospect)
Vendor	Atul Kaila — Solutions Engineering
Date	September 2026
Reference	SOW-VDA-2026-001
Deployed prototype	ai-vehicle-claims-prototype-p6sy.vercel.app
Source	github.com/atulkaila/ai-vehicle-claims-prototype

1. Project Scope

An AI-assisted claims intake application that accepts a photograph of a damaged vehicle and returns a structured preliminary assessment — vehicle identification, damage summary, repair-cost range, per-section confidence, and a human-review recommendation. Delivered as a working prototype and proposed for a 4-week pilot before wider rollout.

In scope (prototype, delivered):

- Single-page web application (Next.js + TypeScript) on Vercel
- File upload (JPEG / PNG / WebP, ≤ 4 MB) or public image URL input
- Server-side call to a vision-capable LLM with a strict JSON output schema
- Runtime schema validation (Zod); same-page results with independent confidence per category
- Customer-safe error envelope with codes for invalid input, oversized image, unreachable URL, model failure, and schema mismatch
- Anonymous public demo with encrypted server-side API-key storage

Out of scope (prototype): claims history, image persistence, authentication, claims-system integration, autonomous claim decisions, repair-shop integration, parts-pricing catalogues, labour-rate databases, payment processing, RBAC, enterprise audit logging, calibrated confidence, model routing, multi-agent orchestration, rate limiting.

Delivery phases:

Phase	Status	Purpose
Prototype	Delivered	Prove technical feasibility and customer experience
Pilot (4 weeks)	Proposed	Select the production-ready platform, migrate, run against real claims, decide on wider rollout

Production rollout beyond the pilot is a separate engagement scoped after pilot evaluation (M5).

2. Technical Approach

Architecture (single Next.js full-stack app, one API route, one shared JSON schema): Browser → /api/analyse (Vercel serverless, Node.js) → OpenAI Chat Completions (gpt-4o-mini , vision + JSON mode) → Zod schema validation → typed Assessment JSON → Browser. The browser never talks to the model directly; the API key stays in Vercel's encrypted environment variables.

AI/ML model: OpenAI gpt-4o-mini selected for the prototype: multimodal vision, ~2-second latency, ~US\$0.0002 per assessment, native JSON output. The system prompt fixes the schema, enforces confidence bounds (0–1), locks the currency to GBP, and instructs the model to return Unknown values with reviewRequired=true for non-vehicle or ambiguous images rather than fabricate a claim. Zod validates every response; invalid responses surface as INVALID_MODEL_RESPONSE , not partial data.

Integration points (prototype): OpenAI Chat Completions API; GitHub for source control; Vercel for hosting, CI, and encrypted environment variables.

Platform selection for the pilot (M2 decision): Deferred to design phase so the choice is grounded in the customer's cloud footprint, GDPR posture, existing SSO provider, and downstream integration targets rather than assumed. Two viable stacks:

- **Option A — Harden on Vercel + OpenAI:** Vercel Pro (Firewall, rate limits), Vercel KV, Vercel Postgres for claim history, Auth.js with Entra ID via OIDC, OpenAI enterprise plan with DPA, Sentry for telemetry.
- **Option B — Migrate to Azure:** Azure App Service or Container Apps, Azure OpenAI behind managed identity, native Entra ID, Azure Cosmos DB, Azure API Management for rate limits and audit, Application Insights.

Both options meet the same target architecture (auth, persistence, telemetry, rate limiting, safe secret handling); only the vendor supplying each layer differs. M3–M5 are written platform-agnostic — only M2 depends on the choice.

Defensive layers: client-side MIME + size validation → client-side URL syntax and preview verification → server-side re-validation + SSRF guard blocking loopback and RFC1918 → Zod schema enforcement → customer-safe error envelope.

3. Milestones and Timeline

Total duration: 4 weeks from pilot kickoff. M1 is the delivered prototype; M2 is the platform + design decision; M3–M5 execute against whichever platform is chosen in M2.

#	Milestone	Target	Key Deliverables
M1	Prototype (delivered)	Day 0	Deployed demo, GitHub repo, README, SOW
M2	Platform decision & design	Week 1	Selected platform, success criteria agreed, evaluation dataset spec (200 labelled claims), platform resources provisioned, SSO / Entra ID app registration
M3	Hardening & migration	Week 2	Auth wired (Entra ID), claim history persisted, telemetry live, rate limiting applied, secrets managed on chosen platform, model access configured (managed identity or enterprise DPA)
M4	Pilot execution	Week 3	200–500 real claim images processed by 3–5 assessors, daily telemetry monitoring, prompt-tuning against evaluation set
M5	Evaluation & production readiness	Week 4	KPI report vs targets, confusion matrix, human-review workflow, operational runbook, go/no-go decision on wider rollout

4. Risk Assessment

#	Risk	Impact	Likelihood	Mitigation
R1	Model hallucinates make/model or cost	High	Medium	Human review threshold, confidence gating (<0.7 → review), evaluation dataset, quarterly re-tuning
R2	API key or credential leaked	High	Low	Server-side only, encrypted vault, rotation, SIEM alerts; managed identity replaces the key entirely if Azure is selected in M2
R3	Model provider outage	Medium	Low	Graceful <code>MODEL_ERROR</code> envelope, retry with exponential backoff, secondary provider on hot standby
R4	Image PII / GDPR (plates, faces, VINs)	High	Medium	No persistence in prototype; region-locked hosting + retention policy + redaction pipeline in production
R5	Runaway API cost from abuse	Medium	Medium	Monthly billing cap; Vercel Firewall / APIM rate limits; budget alerts at 50 / 80 / 100 %
R6	Adversarial or fraudulent submissions	High	Medium	Content-moderation pre-check, image forensics (EXIF, error-level analysis), confidence gating, human review
R7	Regulatory rejection (FCA, ICO)	High	Low	Positioned as decision support (not decision); audit log of every prediction and human override
R8	Model version drift changing outputs	Medium	High	Pin model version; run evaluation dataset before promoting new versions; alert on KPI regressions

5. Success Metrics (KPIs)

#	KPI	Target	Measurement
K1	Schema-valid response rate	≥ 99 %	Zod parse success ÷ total requests
K2	End-to-end latency (P95)	< 10 s	Server-side timing telemetry
K3	Assessor agreement on make/model	≥ 85 %	Sample audit of 100 random claims per month
K4	Assessor agreement on severity	≥ 75 %	Same audit sample
K5	Cost per assessment	< £ 0.01	API spend ÷ number of assessments
K6	Human-review routing precision	≥ 80 %	Cases correctly flagged ÷ total flagged
K7	Availability	≥ 99.5 %	Uptime monitor
K8	Security incidents	0	Quarterly key-management + access-log audit
K9	Submission-to-first-look time	< 2 min	Workflow instrumentation
K10	Cost avoidance per adopted claim	Baseline in pilot	Compared to average manual-only cost